Resumen de hallazgos — Auditoría móvil DIVA Android

Práctica de laboratorio 06 — Seguridad en Aplicaciones | Paquete: jakhar.aseem.diva | Entorno: MuMuPlayer (Android 15, x86_64) | Datos ficticios, entorno autorizado

ID	Componente afectado	Procedimiento	Evidencia	Impacto	Corrección propuesta
D01	LogActivity.java:56	Ingreso de tarjeta de prueba 4111111111111111 en «Insecure Logging» y captura de logcat.	logcat: Log.e("diva-log", ...) con el número completo (04_logcat_completo.txt)	Una app con permiso de logs o acceso ADB recupera datos financieros sin interacción.	No registrar el valor; usar una referencia no reversible (últimos 4 dígitos).
D02	HardcodeActivity.java:44	Decompilación con JADX; ingreso de la clave hallada «vendorsecretkey» en el campo.	Toast «Access granted!» (04_toast_granted.png)	La decompilación revela el secreto; compromete cualquier control basado en él.	No embeber secretos en el cliente; validar contra un backend.
D03	InsecureDataStorage1Activity.java	Guardado de credenciales de prueba; lectura de SharedPreferences con run-as.	shared_prefs/...xml en texto plano (03_shared_prefs.xml)	Root, run-as o copia de seguridad exponen credenciales en claro.	Usar EncryptedSharedPreferences (Jetpack Security).
D04	InsecureDataStorage2Activity.java	Guardado de credenciales de prueba; consulta SQLite con run-as + sqlite3.	tabla myuser en texto plano (01_sqlite_query.txt)	Root, run-as o copia de seguridad exponen credenciales en claro desde la BD.	Cifrar la BD (SQLCipher) o las columnas sensibles con clave en Keystore.
D05	SQLInjectionActivity.java:70	Payload x' OR '1'='1 en el campo de búsqueda; resultado verificado ejecutando la consulta inyectada contra la BD sqli.	3 usuarios y tarjetas con una sola consulta (04_resultado_3_usuarios.txt)	Elude el filtro; expone credenciales y datos financieros de todos los usuarios.	Consulta parametrizada (rawQuery con ?) en vez de concatenación.
D06	InsecureDataStorage3Activity.java	Guardado de credenciales; lectura del archivo temporal en el directorio de la app con run-as.	archivo uinfo*tmp en texto plano (02_archivo_temp.txt); permisos -rw------- (solo propietario)	Credenciales en claro en un archivo que persiste; legibles con root, run-as o copia de seguridad.	No guardar credenciales en archivos temporales; cifrar con EncryptedFile y borrar el archivo.
D07	InputValidation2URISchemeActivity.java	WebView con JavaScript habilitado; carga de file:///data/data/.../shared_prefs/...xml.	El WebView muestra el contenido del archivo interno (03_webview_file_content.png)	Lectura arbitraria de archivos del sandbox de la app por el esquema file://.	Restringir loadUrl a https y deshabilitar el acceso a file:// en el WebView.
D08	APICredsActivity (manifiesto; exportada por intent-filter)	Invocación directa de la acción VIEW_CREDS sin abrir la app (am start -a).	Pantalla de credenciales API mostrada directamente (01_creds_via_intent_externo.png)	Cualquier app instalada extrae las credenciales del proveedor sin interacción del usuario.	exported=false o permiso de nivel signature.
D09	APICreds2Activity.java	Invocación directa de VIEW_CREDS2 con el extra check_pin=false.	Credenciales API Tveeter mostradas sin PIN (01_bypass_pin.png)	El control de acceso depende de un dato enviado por el llamador; no hay validación real.	Validar el PIN en el servidor; no decidir con un extra del intent.
D10	NotesProvider (manifiesto; exported=true)	Consulta directa al ContentProvider con «content query» sin pasar por la app.	6 notas privadas expuestas (01_notas_filtradas.txt)	Lectura (y potencial escritura) de datos personales por cualquier app instalada.	exported=false o permiso signature + validar al llamador.

Correcciones aplicadas

Corrección A (Insecure Logging): LogActivity.java. Se reemplazó el registro del número de tarjeta completo por una referencia enmascarada (últimos 4 dígitos). Verificado en logcat: *Card ref: ****1111*; la función sigue mostrando el mismo mensaje de error al usuario.

Corrección B (inyección SQL): SQLInjectionActivity.java. Se reemplazó la consulta concatenada por rawQuery parametrizado. Verificado: el payload x' OR '1'='1 se trata como valor literal y devuelve 0 filas; la búsqueda legítima «admin» devuelve su registro igual que antes.